

SUGAR Cosmetics — DPDP Implementation Guide

Getting compliant by 13 May 2027 without losing the customer data the business runs on

Prepared for the management committee · 4 August 2026

The situation, and the principle this guide works on

The Digital Personal Data Protection Rules were notified on 13 November 2025. The obligations that affect us — notice, consent, purpose limitation, minimisation, security, breach reporting, retention and customer rights — commence on **13 May 2027**, nine months from now. There is no grace period; enforcement begins on day one.

The instinct on reading the Act is that it forces us to collect less. That is half right, and taking it as the whole truth would be expensive. The Act restricts the *basis* on which we collect personal data, the *purposes* we may put it to, and the *proof* we hold that we asked properly. Within a stated purpose it does not cap volume, and it does not restrict what we analyse.

The practical consequence is that a well-executed programme should leave SUGAR with **more usable first-party data than it has today** — because data collected against a recorded, specific consent is data we can keep, join, model and defend, while data collected the way we collect it now is data we would have to delete if challenged. The task is to change the basis without losing the volume.

What this actually costs us

Area	Realistic impact
First-party analytics — RFM, cohorts, basket, lifetime value	Continues, but the historical tail is at risk from the retention rules. Aggregate and de-identify the derived features before raw records are erased and the models are safe.
Total customer records collected	No material fall if consent is designed for opt-in rate. A poorly designed consent screen converts at 20–30%; a well designed one at 65–80%. This is a conversion problem, not a legal one.
Advertising to platform audiences	Reduced to the share of the base that gave a sharing consent. Recoverable, and proportional to how well the consent screen is designed.
Advertising to identified under-18 users	Ends. The one genuine non-recoverable loss, and it is small — under-18s are a minority of the transacting base.
Fields collected per customer	Falls. Minimisation means every field needs a named purpose. Most loyalty forms lose a third of their questions and lose nothing else.
Effort	Roughly two quarters of part-time work across digital, CRM, retail operations, data and legal. No new platform purchase is required, though a consent management tool is worth pricing.

Penalties are ceilings per breach category, not a cap per incident: ₹250 crore for a failure of security safeguards, ₹200 crore for breach notification, ₹200 crore for the children's obligations, ₹50 crore otherwise. One badly handled breach can trigger three of them at once. The more likely commercial damage, though, is simpler — having to delete a customer base whose consent we cannot evidence.

A planning risk worth naming now

The eighteen-month runway is not guaranteed. MeitY consulted in January 2026 on compressing it to twelve months, which would pull full enforcement back to November 2026 — four months away rather than nine. [UNVERIFIED whether this will be adopted.] The plan is therefore ordered so that the cheapest, highest-exposure items land first and a compression announcement would cost re-sequencing rather than failure.

1. What SUGAR collects, and where it enters the business

Eleven entry points. Layers follow the course convention — (–1) external and anonymous, (0) our own assets, (+1) identity resolved.

Entry point	Layer	What we collect	What we use it for	Who else receives it
Website checkout	(0)→(+1)	Name, mobile, email, address, order history, device and IP	Fulfilment, payment, then re-marketing	Payment gateway, courier, Meta and Google tags
Mobile app	(+1)	As above, plus device ID, push token, browsing and wishlist	Personalisation, push campaigns, retargeting	Attribution SDK, Firebase, Meta, Google
Virtual try-on and shade match	(0)	Camera image; derived shade value	Shade recommendation	Try-on SDK vendor
Beauty quiz and skin profile	(0)→(+1)	Skin type, tone, concerns, preferences	Recommendation and segmentation	CRM and email platform

Entry point	Layer	What we collect	What we use it for	Who else receives it
Exclusive outlets and kiosks (100+)	(+1)	Mobile number taken at billing; name	Bill delivery, then SMS and WhatsApp campaigns	POS vendor, SMS aggregator, WhatsApp provider
Multi-brand counters (~45,000)	(+1)/(-1)	Collected by the retailer, not by us	Retailer's own CRM	Lifestyle, Shoppers Stop, chemist chains
Marketplaces — Nykaa, Amazon, Flipkart, Myntra	(-1)	Order and SKU data; no customer identity	Sales reporting, demand planning	The marketplace holds the customer relationship
WhatsApp and SMS	(+1)	Mobile number, opt-in state, message and click history	Campaigns and order updates	WhatsApp provider, SMS aggregator
Influencer content and customer reviews	(-1)/(0)	Public posts; customer-submitted photos and reviews	Content and social listening	Meta, listening tool
Meta and Google audience uploads	(+1) → (-1)	Hashed phone and email lists from our CRM	Retargeting and lookalike prospecting	Meta, Google
Customer care and returns	(+1)	Order history, complaint transcript	Service and refunds	BPO vendor, ticketing platform

Two observations shape everything that follows. The offline estate is where we collect the most and evidence the least — a number taken verbally at a till leaves no record that we ever asked. And the marketplace channel, roughly 40% of revenue, is largely not our compliance problem, which usefully reduces scope.

2. What the Act requires of SUGAR

We are a Data Fiduciary under S.2(i) for everything we collect directly, and the Act reaches us under S.3(a). Liability sits with us and does not move to a vendor. Each row states where we stand today so the size of the gap is visible.

Requirement	Why it applies to us	Where we stand today	Provision
Give notice at the point of collection	Eleven entry points; at most two show anything resembling a notice. The till shows none.	A policy linked in the website footer, which is not a notice at collection	S.5; Rule 3
Take consent that is free, specific, informed, unconditional, unambiguous and by clear affirmative action	Signup bundles fulfilment, marketing and personalisation into one acceptance. Conditioning the bill on the number would make it coercive.	One tick covering everything	S.6(1)
Keep a consent record you can produce	We cannot currently show, for any given customer, what they agreed to and when	No consent record exists	S.6(1); Rule 3
Make withdrawal as easy as giving	Consent takes one tap; withdrawal takes an email to support	Email to customer care	S.6(4)–(6)
Use data only for the purpose consented	Models trained on fulfilment data are being used for targeting. Purpose has to be tracked at feature level, not at database level.	No purpose register exists	S.8(3)–(4)
Collect only what the purpose needs	The loyalty form asks for more than any stated purpose justifies. Every surplus field is now a liability rather than an asset.	Collect-first design	S.8(4)
Keep data accurate where it drives a decision about the person	Address and mobile drive delivery; a stale record causes a failed delivery and a refund dispute	Customer self-correction only	S.8(3)
Apply security safeguards	Database access is broad across growth, CRM and support. Analysts export customer tables to spreadsheets.	Platform defaults	S.8(5); Rule 6
Report a breach without delay, detailed report in 72 hours	No runbook, no named caller, no filing template	Nothing	S.8(6); Rule 7
Erase once the purpose is served	Customer records, try-on images and quiz data are kept indefinitely by default	Indefinite retention	S.8(7); Rule 8
Contract properly with processors, and stay liable for them	Seven vendor classes hold live customer data with no data-protection terms. An agency firing an unconsented campaign is our penalty, not theirs.	Commercial contracts only	S.8(1)–(2)
Answer access, correction, erasure and nomination requests	No intake route; requests arrive as support tickets	Ad hoc	S.11–S.14
Publish a grievance contact and resolve within 90 days	Not published on site, app or packaging. A customer must exhaust our channel before going to the Board, so this is our first and cheapest line of defence.	Generic support email	S.8(9), S.13
Keep cross-border transfers within permitted limits	Dubai and Russia operations, plus overseas SaaS. Sectoral rules still bind — RBI's payment-data localisation is unaffected by this Act.	No data-location register	S.16

2.1 A note on the children's requirement, because it is easy to over-read

A child is anyone under eighteen. S.9 requires verifiable parental consent before processing a child's data, and prohibits tracking, behavioural monitoring and targeted advertising directed at children outright — there is no consent that makes those lawful. Rule 10 requires reasonable and appropriate technical and organisational measures to establish that consent.

The cautious reading is that until every user is age-assured, none may be advertised to. That is not the standard the Act sets, and it would be commercially unworkable. The standard is due diligence: ask the question, act on the answer, and do not design systems so as to avoid knowing. A business that captures date of birth at signup, routes declared under-18s out of advertising audiences, and does not buy interest segments that are obviously juvenile has done what the provision asks. What is indefensible is our present position — collecting nothing about age and advertising to everyone.

The commercial point is sharper than the legal one. If we cannot reliably tell whether a user is a child, we cannot safely profile any of them. Age assurance is therefore not a product nicety; it is the gate on the entire personalisation stack, which is why it is the first thing in the plan and costs a week of engineering.

2.2 Who is the Data Fiduciary at a multi-brand counter?

This governs roughly 45,000 touchpoints, so it is worth settling in writing. S.2(i) attaches the obligation to whoever determines the purpose and means.

Situation	Who determines purpose	Our position
The retailer enrolls the shopper in its own loyalty scheme	The retailer alone	We are not a Data Fiduciary. Take a written attestation that no SUGAR-directed collection occurs and stop there.
Our own beauty advisor, on the retailer's floor, collects numbers for SUGAR campaigns	We do	We are the Data Fiduciary. A scripted one-line request at the till, with the answer recorded on the POS, discharges it.
The retailer shares a customer list with us for a joint campaign	Both, jointly	Both are Fiduciaries. Needs a data-sharing agreement and a consent, taken by the retailer, that names SUGAR. Without it we decline the list — inherited consent is not consent.

3. What does not apply to us

Five scoping decisions that remove work. Each is deliberate, and each is something an adviser trained on European law is likely to get wrong in India.

- There is no sensitive-personal-data category.** The Act has one flat class of personal data. Skin tone, skin concerns and try-on images get no elevated treatment as they would under Article 9 of GDPR. They still need notice, consent, minimisation and erasure — they do not need a separate architecture. The corollary is less comfortable: our ordinary customer database gets exactly the same treatment as anything else.
- There is no legitimate-interest ground.** Processing rests on consent or on the closed list of legitimate uses in S.7, which covers State functions, legal compliance, medical emergencies, disasters and employment. Marketing, advertising, profiling, personalisation and analytics are not on that list. We cannot reason our way to retargeting; we have to consent our way to it.
- There is no general data-localisation mandate.** S.16 works as a blacklist, not a fortress — transfer is permitted to any country except those the Government restricts by notification, the reverse of the European whitelist. Our overseas cloud and martech stack does not need repatriating. It does need a named owner and a location register, and RBI's separate payment-data rules still apply.
- Marketplace buyers are largely not our Data Principals.** On Nykaa, Amazon, Flipkart and Myntra the marketplace determines the purpose and means for customer identity; we receive orders without identity. Our duty is limited to whatever identified data we do receive, and to not re-identifying buyers. This removes about 40% of revenue from the consent programme's scope.
- The fixed erasure clock does not reach us yet.** The Third Schedule attaches automatic deletion, with 48 hours' notice to the customer, to e-commerce entities holding two crore or more registered Indian users. We are below that threshold. The sources conflict on the period — one year of no contact in one, three years from last approach in another — and the difference is worth resolving before our user count grows, because a one-year rule would cut the modelling tail severely. The general duty in S.8(7) to erase once the purpose is served applies to us in full regardless.

Also outside scope for now: the Significant Data Fiduciary obligations — a Data Protection Officer resident in India and responsible to the board, an annual independent audit, a periodic impact assessment, and algorithmic due diligence over recommendation and scoring models. These attach only on notification by the Government, and none has been made. Treat the list as the maturity model rather than as work: appointing a compliance lead now means a notification would be an escalation rather than a standing start.

4. What to do, who owns it, and what proves it was done

Twenty-nine actions in five workstreams. Each answers a requirement the Act places on us, and each has one named owner and one piece of evidence that could be produced in an inquiry. Effort is estimated honestly. No new platform purchase is required, though a consent management tool is worth pricing against the build in workstream B.

#	Action	Owner	Evidence it is done	Effort	By
A. MAP, NAME THE PURPOSE, MINIMISE — unglamorous, and where the whole programme succeeds or fails					
A1	Map every system, field and flow: POS, e-commerce, app, CRM, loyalty, WhatsApp, call centre, agencies, try-on SDK	Data Lead	Data map signed off by each system owner; field-level inventory	1 month	Sep 26
A2	Build a purpose register — a named lawful purpose against every field. Anything unnamed is a candidate for deletion	Data Lead with Legal	Purpose register; list of fields with no purpose	1 month	Oct 26
A3	Minimise. Cut the fields no purpose justifies, starting with the loyalty enrolment form	Head of Digital with Data Lead	Before/after field count per form; deletion record for dropped historical fields	3 weeks	Nov 26
A4	Track purpose at feature level in the model store, so a feature built for fulfilment cannot be silently reused for targeting	Data Lead	Feature catalogue carrying a purpose tag; blocked-reuse log	1 sprint	Jan 27
A5	Aggregate and de-identify the derived facts — RFM scores, cohort curves, basket rules — before the raw records they came from are erased	Data Lead	Derived-feature store populated; models retrained and compared against the raw-data baseline	1 sprint	Feb 27
B. NOTICE AND CONSENT — the workstream that decides how much data we keep					
B1	Redesign the signup and checkout notice and consent: itemised, standalone, plain language, four separately revocable purposes, value stated for each	Head of Digital with Legal	Live screen; opt-in rate by purpose tracked weekly like any other conversion metric	1 sprint plus design	Nov 26
B2	Build the consent record: purpose, timestamp, channel, notice version, withdrawal state, retrievable per customer and immutable	CTO with Data Lead	A named customer's consent history produced on request within a day	3–4 weeks	Dec 26
B3	Add a date-of-birth field at signup and prompt existing accounts at next login	Head of Digital	Field live; weekly share of active accounts with an age on file	1 week	Oct 26
B4	Exclude declared under-18 accounts from every advertising audience, and build the parental-consent route so the segment is served rather than lost	CRM Manager, then CTO	Export query signed off; audience counts before and after; parental consents held	2 weeks, then 1 sprint	Nov 26 / Mar 27
B5	Make withdrawal one tap in the app and STOP on WhatsApp and SMS, wired straight to campaign suppression and cascaded to processors	CRM Manager	Time from withdrawal to suppression, target under 24 hours	2 weeks	Jan 27
B6	Publish the notice in English and the Eighth Schedule languages that match our order volume by state	Legal	Published translations; language-selection event in analytics	4 weeks	Feb 27
B7	Re-consent the legacy base with a real offer attached, before the deadline rather than after it	Head of Growth with CRM	Campaign sent; consented base size before and after; decline rate by segment	1 quarter	Mar 27

#	Action	Owner	Evidence it is done	Effort	By
B8	Decide whether to appoint a registered Consent Manager. Registration opens 13 Nov 2026 and then closes to new entrants, so the decision has its own deadline	Compliance lead with CTO	Written decision with reasons, taken to the management committee	Decision	Dec 26
C. THE OFFLINE TILL — widest gap, longest lead time, so it starts early					
C1	Add a consent flag to the POS so the advisor records what the customer agreed to at the till	Head of Retail Operations with the POS vendor	Field live in production; consent fill-rate by store, weekly	1 quarter with vendor	Jan 27
C2	Issue the counter script to every exclusive outlet and kiosk	Head of Retail Operations	Script at every till; mystery-shopper check at 5% of stores	4 weeks	Jan 27
C3	Train beauty advisors — what may be collected, how to ask, how to take a refusal without losing the sale	Retail Operations with L&D	Attendance and quiz records	1 quarter	Feb 27
C4	Determine in writing whether we are the Data Fiduciary at each multi-brand partner, and paper it	Legal with Head of Trade	Written determination; attestation or agreement on file per partner	Legal time	Feb 27
D. THIRD PARTIES, TAGS, SECURITY AND RETENTION					
D1	Build the processor register: vendor, data held, volume, location, contract status	Data Lead	Register, reviewed quarterly	2 weeks	Oct 26
D2	Issue the DPDP contract addendum to every processor	Legal	Signed addenda counted against the register; escalation list for refusals	Legal time, ~7 vendors	Feb 27
D3	Audit every tag, pixel and SDK on the site and in the app; remove what has no purpose and gate the rest on consent state	CTO with Head of Digital	Tag inventory; automated test proving no marketing tag fires for a withdrawn user	3 weeks, then quarterly	Dec 26
D4	Stop retaining try-on images beyond the session; keep the derived shade code	CTO	Storage configuration; vendor confirmation	Configuration change	Oct 26
D5	End customer-table exports to spreadsheets. Give analysts a masked working environment instead	Data Lead with CTO	Export logs showing the practice has ceased; masked environment in use	1 sprint	Feb 27
D6	Apply Rule 6 safeguards: encryption, masking or tokenisation, role-based access, logs retained one year, tested backups	CTO	Access matrix; encryption attestation; log retention proof; restore test	1 quarter	Apr 27
D7	Set a retention period per data class and automate deletion, cascading to CRM, email platform and processors	Data Lead	Retention policy; deletion logs; downstream propagation test	1 sprint	Apr 27
D8	Write and rehearse the 72-hour breach runbook	CTO with Legal	Runbook signed off; drill minutes timed against the clock	2 weeks plus a drill	Apr 27
E. GOVERNANCE AND CUSTOMER RIGHTS					
E1	Appoint a compliance lead accountable for this register; standing quarterly item at the management committee	CEO's office	Appointment letter; board minutes carrying register status	Appointment	Sep 26
E2	Publish the grievance contact on the site, in the app, on packaging and in the notice	Legal	Live in all four places; first-response and 90-day resolution rates	2 weeks	Jan 27

#	Action	Owner	Evidence it is done	Effort	By
E3	Build the customer request workflow — access, correction, erasure, nomination, withdrawal — cascading to processors	Head of Customer Experience	Ticket queue by request type; monthly service-level report	1 sprint	Apr 27
E4	Add self-service privacy controls in the app so most requests never become tickets	Head of Digital	Feature live; share of requests self-served	1 sprint	Apr 27

A rule worth adopting: an action is not complete when the work is finished, but when the evidence named against it exists and can be produced within a working day. Compliance that cannot be demonstrated is not compliance.

5. Sequence, and why in this order

Almost everything is due on the same date, so due dates cannot set the order. Three things do: whether an activity is currently prohibited rather than merely undocumented, how long the work takes regardless of when it starts, and what unlocks other work. The mapping and purpose register come first not because they are urgent but because nothing downstream can be designed without them.

Phase	Window	What gets done	Why here
Phase 1	Aug – Nov 2026	Data map and purpose register; minimisation; date of birth at signup and audience exclusion; try-on images stopped; tag and pixel audit; processor register; compliance lead appointed; consent screen redesigned	The map and register unlock every later decision, and they take a quarter of unglamorous work. Alongside them sit the cheap, fast items that remove the exposures we cannot defend at all — advertising to users we have never asked about, and holding facial images with no purpose.
Phase 2	Nov 2026 – Feb 2027	POS consent flag; counter script and advisor training; consent record built; withdrawal wired through and cascaded; vendor addenda; multi-brand position papered; translations; grievance contact published; re-consent campaign; Consent Manager decision	The till is the longest pole in the plan — a POS change plus training several thousand advisors takes a quarter whatever we do. The re-consent campaign runs here so that we learn the real size of our consented base in early 2027, not in May.
Phase 3	Feb – May 2027	Security safeguards; masked analyst environment; retention and deletion; derived-feature store; breach runbook and drill; request workflow; self-service controls	Each is a discrete build with a predictable duration and no dependency on the others. They have to be demonstrably live on 13 May 2027, and every one is dated to complete by mid-April so the first breach drill has time to find something.
After	From May 2027	Operate the register; review the consent funnel monthly; audit tags quarterly; watch two thresholds	The thresholds are registered-user count, which moves us into the Third Schedule erasure rules at two crore, and any Government notification of Significant Data Fiduciaries.

If the runway is compressed to twelve months, Phase 3 collapses into Phase 2 and the order does not change — the security, retention and rights builds are staffed in parallel rather than in sequence, at higher cost. Nothing in Phase 1 would move, which is the point of putting the cheap high-exposure items there.

6. What changes for marketing and retail analytics

Six things in our analytics change, one short list of practices stops, and most of the analytical function continues untouched. The planning question is not whether customers will consent. It is what still works when a large share of them do not.

6.1 The six changes

What changes	Why	What we do about it
The unique identifier and the single customer view	Everything at the (+1) layer depends on attaching an identity to a transaction. Consent now decides who may be stitched at all, so the unified view becomes a consented subset rather than the whole base.	Report the consented share of the base as a standing metric. Treat growing it as a growth objective, not a legal one.
RFM, lifetime value and churn	These need history, and retention limits and erasure rights cut the tail. The dormant cohort we most want to model is the one we may no longer keep.	Move the durable value into aggregated, de-identified derived features before the raw records go.
Attribution	Deterministic cross-device linking narrows as consent narrows.	Incrementality testing and geo experiments stop being second-best and become the primary causal method.
Personalisation engines	Purpose limitation means a model trained on data collected for fulfilment cannot quietly be repurposed for targeting.	Track purpose at feature level, not at database level, and block reuse in the model store.
How analysts work with data	Exporting the customer table to a spreadsheet for a quick look is over. Enterprise data increasingly cannot leave the enterprise.	Masked environments, clean rooms and synthetic data become the normal working surface.
Vendors and agencies	Processors act on our instructions and under our contract. Their mistake is our penalty.	Vendor governance becomes part of the analytics function rather than a procurement afterthought.

6.2 What stops

Practice	Why	Recoverable?
Targeted advertising to users who have told us they are under 18	Prohibited outright under S.9(3); no consent cures it	No. The one permanent loss, and it is small.
Uploading CRM lists to ad platforms under the consent taken for order fulfilment	Pushing our customer data into an ad platform is a purpose we never disclosed; S.6(1) requires the consent to be specific	Yes — by adding the sharing purpose to the consent screen
Taking a mobile number at the till without saying what it is for, or implying it is required	No notice under S.5, and conditioning the bill on it makes the consent unfree under S.6(1)	Yes — one sentence of script
Bundling marketing consent into acceptance of terms, and consent buried in the T&Cs	The notice must stand alone and be itemised; dark patterns void the consent entirely	Yes — unbundle into four purposes
Loyalty enrolment as a data harvest — fields collected because someone might need them later	Minimisation. Every surplus field is a liability without a purpose	No, and we should not want it back
Buying or renting third-party phone lists	We cannot inherit a consent we never obtained	No. Grow the base through owned channels.
Blasting the legacy database on old bundled consent	Undocumented consent will not support a campaign in May 2027	Yes — through the re-consent campaign, at a known cost in list size
Tags and pixels still firing after opt-out	A forgotten script processing a withdrawn user is the clearest possible evidence of failure	Yes — tag audit and consent gating

6.3 The forty-per-cent test

Assume four in ten customers decline the marketing and sharing purposes. That is a planning assumption, not a forecast. [UNVERIFIED — replace with our own decline rate once the redesigned screen has run for a month.] Here is what survives it.

Metric or method	At 40% decline	Why, and what to do
Repeat purchase rate, retention, cohort curves	Intact	Computed on transaction records, which we hold for fulfilment. Consent state does not enter.
Basket analysis, affinity, cross-sell rules	Intact	Runs on baskets, not on people. Can be computed on de-identified transactions.
RFM segmentation	Intact for the consented base	The scores are unaffected; the addressable share of each segment falls. Report segment size and addressable size as two numbers.
Lifetime value and payback	Intact, with a caveat	Margin and frequency are unaffected. The historical tail is at risk from erasure, so persist the derived curves.
Marketing efficiency ratio at business level	Intact	Total revenue over total investment needs no identity at all. This becomes the headline number.
Media mix modelling, geo and holdout tests	Intact	Aggregate methods. Unaffected by consent state, and they become the primary causal read.
Platform-reported ROAS	Degrades	Fewer matched users means less of the journey is observable, so ROAS falls without the business falling. Plan for it or it will read as a crisis in mid-2027.
Custom audiences and lookalikes	Falls to 60%	Directly proportional to sharing consent. This is the metric that pays for good consent design.
One-to-one personalisation	Falls to 60%	Contextual and segment-level personalisation covers the rest, and the quality of the creative starts to matter again.

Second-order effect worth stating to the board in advance: the first quarter after the age gate and consent redesign go live will show falling reach and falling attributed ROAS at the same time. Both are mechanical. Agreeing now which numbers will move, and by roughly how much, is what stops that quarter being read as a marketing failure and reversed.

6.4 Designing the exchange, and pricing it

If consent is the front door to our data rather than a formality at the bottom of a page, then the question is what makes a customer want to walk through it. Six things decide our consented base.

1. **Make the loyalty programme the consent vehicle.** A single enrolment can carry all four purposes, be refreshed annually, and work identically online and at the till. It is the highest-leverage move available, because it turns a compliance obligation into the identity spine the analytics function has wanted anyway.
2. **Price the exchange honestly.** A first-order estimate: if a consented customer is worth roughly the incremental margin that personalisation and retargeting produce over an unconsented one, then anything we offer below that figure is profitable. Early access to launches and a shade-match history cost us almost nothing and are worth more to this customer than a discount, which costs margin and trains the discount habit. Run the arithmetic on our own numbers before choosing the incentive.
3. **Ask at the moment of value, not the moment of friction.** Consent requested at checkout competes with the purchase. Requested when the first delivery lands, or when the customer opens the app to track an order, it converts materially better.
4. **State the benefit, not the legal basis.** "Get restock alerts for the shades you buy" outperforms "we may process your personal data for marketing purposes". The Act requires clarity — it does not require the language to be off-putting.
5. **Unbundle, but do not fragment.** Four purposes is the right granularity. Twelve toggles depresses opt-in and helps nobody, including the customer.
6. **Treat opt-in rate as a KPI with an owner.** It is a conversion metric and responds to the same tools — placement, wording, timing, incentive. Give it to Growth, review it monthly, test it. A target above 65% for the marketing purpose is realistic; the sharing purpose will run lower and should be measured separately.

6.5 What to build instead

- **A consent management capability** that captures and proves consent across web, app, POS and the call centre, with a standing audit of what is actually firing.
- **First-party, server-side measurement** on our own infrastructure and tied to consent state, rather than depending on third-party device identifiers.
- **Privacy-preserving measurement** — aggregated reporting, media mix modelling, geo and holdout experiments, and clean rooms for partner work.
- **A masked and synthetic working environment** for analysts. Synthetic data serves perfectly well for pipelines, dashboards and model plumbing; it misleads wherever the question depends on the true shape of the tail — rare high-value customers, fraud, outliers. Draw that line explicitly rather than by default.

- **Contextual and creative strength.** When we cannot target the person we target the moment.

6.6 The argument to make if the cost is challenged

The objection will be that the expected penalty is smaller than the cost of compliance. Four answers that do not rely on ethics.

1. **The penalties stack.** They are ceilings per breach category, so one mishandled incident can trigger the security failure, the notification failure and the children's failure together. The mental arithmetic uses one number where the law uses three.
2. **The enforceable asset is the consent record, not the data.** A customer base whose consent we cannot evidence is a base we may be required to stop using. That is a write-down of the marketing database, and it appears nowhere in the penalty calculation.
3. **The work returns something regardless.** Mapping the data, naming a purpose for every field and cutting what has none is the programme a well-run data organisation runs anyway. Consent designed as a conversion surface raises opt-in, which raises the addressable base.
4. **The cost is reputational, not transactional.** The Board publishes its orders and there is no compensation regime. In a category where the brand is the asset, being the first named cosmetics retailer costs more than the fine.

7. Assumptions, limitations, sources and note on AI use

Assumptions about current practice

This guide is written without inside knowledge of SUGAR's systems, as the brief allows. Each assumption is stated so a reader who knows better can correct it without disturbing what is built on it.

Assumed	If wrong
No age question is asked at signup today	The age field and the audience exclusion become verification rather than build; nothing else moves
Consent at signup is a single bundled acceptance	The consent redesign falls away; the consent record is still required
No purpose register or data map exists	The first workstream shortens to a review, and the plan gains a month of slack
Counter staff take numbers verbally with no stated purpose	The offline workstream halves; the POS consent flag is still needed as evidence
Marketing tags and SDKs fire without regard to consent state	The tag audit becomes a confirmation rather than a remediation
Try-on images are retained server-side by the vendor	That action becomes a confirmation from the vendor rather than a change
Fewer than two crore registered Indian users	If wrong, the Third Schedule erasure clock and the 48-hour pre-erasure notice apply, and the retention work becomes a significantly larger build
Not notified as a Significant Data Fiduciary	If notified, add a Data Protection Officer resident in India, an annual impact assessment, an independent audit and algorithmic due diligence — roughly two further quarters

Limitations

- Outlet count, city coverage and the offline share of revenue come from trade press rather than company filings. They establish scale and nothing is computed from them.
- The opt-in benchmarks and the forty-per-cent decline assumption are drawn from general practice, not from SUGAR data. [UNVERIFIED] Replace both with our own numbers once the redesigned screen has run for a month.
- The sources disagree on the Third Schedule erasure period — one year of no contact in one, three years from last approach in another. The conflict is surfaced rather than resolved, and it does not currently bite because we are below the user threshold.
- Whether MeitY will compress the eighteen-month runway to twelve is unresolved. [UNVERIFIED] The sequencing is built to survive either outcome.
- This is a compliance framework, not legal advice. Every drafted artefact requires review by counsel before publication.

Note on the use of AI

AI was used substantially: to verify the commencement dates and provision numbers against the notified Rules, to test the reading of the children's clause against published commentary, to surface the conflict on the erasure period, and to draft the artefacts that follow. The judgements are the author's — the choice of organisation, the decision to frame this as a consent-design problem rather than a data-reduction problem, the sequencing logic, the scoping decisions, the forty-per-cent scenario, and the argument to be made if the cost is challenged.

Appendix

Drafts to work from, not descriptions of drafts. All require review by counsel before publication. Not counted toward the page limit.

A. Signup notice and consent screen — drafted text

Owner: Head of Digital with Legal. Satisfies S.5 and S.6(1) and the itemisation requirements of Rule 3. Written for opt-in rate as well as for compliance.

Before you create your SUGAR account

We collect your name, mobile number, email address and delivery address.
If you use shade match, we process your camera image to work out your shade, then delete it. We keep only the shade code.

Choose what you'd like. You can change any of this in one tap, any time, at Profile > Privacy — as easily as you gave it.

☒ Deliver my order and keep me updated on it

Required — we can't ship without this.

☐ Tell me about launches, offers and restocks

By WhatsApp, SMS or email — your choice which.

☐ Recommend shades and products based on what I buy and browse

☐ Show me SUGAR's ads on Instagram, Facebook and Google

We share your number and email in encoded form so the platforms can match you. Say no and you'll still see our ads, just not ones chosen for you.

Your date of birth

For your birthday offer, and because the law requires us to know if you're under 18.

Saying no to any of the last three won't affect your ability to shop, your prices, or your delivery.

You can ask us at any time for a copy of your data, to correct it, or to delete it — and you can nominate someone to do this on your behalf.

Contact: privacy@sugarcosmetics.com

If we don't resolve your complaint, you can complain to the Data

Protection Board of India: [\[link\]](#) Read the full notice >

Available in English and other Eighth Schedule languages

Build notes. The first box is pre-ticked and locked because the processing is necessary to perform the contract. The other three must default to unticked — a pre-ticked box, silence or inactivity is not consent. The notice must stand alone rather than sit inside terms and conditions. Store the notice version against every consent record so a consent given in 2027 can be shown against the wording in force at the time. Track opt-in on each optional box separately; they will behave very differently, and the fourth is the one that pays for the design work.

B. Billing counter script

Owner: Head of Retail Operations. One sentence. Anything longer will not be said.

English

"Can I have your mobile number for the bill? I can send you SUGAR's offers on it too if you'd like — that part's up to you, and you get the bill and every discount either way."

Hindi

"बिल के लिए आपका मोबाइल नंबर ले लूँ? अगर आप चाहें तो SUGAR के ऑफ़र भी उसी पर भेज दूँगा/दूँगी – वो आपकी मज़ी है। बिल और डिस्काउंट दोनों वैसे भी मिलेंगे।"

Then tap one of three buttons on the POS

Customer says	Tap	What it records
Yes, offers too	BILL + OFFERS	Number stored; marketing consent true, timestamped against the transaction and the script version
Just the bill	BILL ONLY	Number stored; marketing consent false. Not eligible for any campaign.
No thanks	DECLINED	No number stored. Bill printed. Sale completes normally.

Three things an advisor must never do

- Enter the store's number, your own, or a colleague's to complete a transaction. Each one creates a false consent record.
- Reuse a number from a previous visit without asking again.
- Tell the customer the number is required, or that the bill depends on it. Making the sale conditional on the number is coercion, and it voids the consent entirely.

Watch the fill rate weekly by store. A store reporting 100% is not compliant — it is almost certainly entering numbers without asking. A store below 40% needs retraining. Expect a healthy 55–80%, and treat both extremes as the audit signal.

C. Purpose register — template and worked rows

Owner: Data Lead with Legal. The single most useful artefact in the programme: a named lawful purpose against every field we hold. Any field that cannot be given one is a candidate for deletion, and deleting it removes the risk rather than managing it.

Field	Where captured	Stated purpose	Basis	Retention	Verdict
Mobile number	Till, web, app	Deliver the bill and order updates	Consent — fulfilment	Life of account	Keep
Mobile number	Till, web, app	Send offers and launch alerts	Consent — marketing	Until withdrawn	Keep, separate tick
Email address	Web, app	Order confirmation and service	Consent — fulfilment	Life of account	Keep
Delivery address	Web, app	Ship the order	Consent — fulfilment	3 years post-order	Keep
Date of birth	Signup	Age assurance and birthday offer	Consent	Life of account	Keep
Camera image	Try-on	Return a shade match	Consent	Session only	Delete at session end
Derived shade code	Try-on	Recommendation	Consent — personalisation	Life of account	Keep
Skin type and concerns	Beauty quiz	Recommendation and segmentation	Consent — personalisation	Until withdrawn	Keep
Hashed phone and email	CRM export	Platform audience matching	Consent — sharing	Refreshed monthly	Keep only if ticked
Gender	Loyalty form	No purpose stated	—	—	Delete field and history
Occupation	Loyalty form	No purpose stated	—	—	Delete field and history
Anniversary date	Loyalty form	Collected, never used	—	—	Delete, or give it a purpose

The last three rows are the point of the exercise. Fields collected because someone might need them later carry the full obligation and produce no value. Running this register across every system is the cheapest risk reduction available, and it is finished work rather than ongoing overhead.

D. Tag, pixel and SDK audit — checklist

Owner: CTO with Head of Digital. Run once now, then quarterly. A forgotten script processing a customer who withdrew is the clearest possible evidence of failure and the easiest thing for a complainant to demonstrate.

- List every tag, pixel and SDK live on the website, the mobile app and the checkout, including any placed by an agency.
- For each, name the purpose it serves and the consent tick that authorises it. Anything without both comes off.
- Confirm marketing tags fire only where the marketing or sharing consent is true, and analytics tags only where permitted.
- Confirm that withdrawal propagates within 24 hours to the tag layer, the CRM, the email platform and the ad platforms.
- Write an automated test that creates a test user, withdraws consent, and fails the build if any marketing tag still fires.
- Record who owns each tag. Unowned tags are removed, not investigated.

E. Processor addendum — clause set

Owner: Legal. For the POS vendor, WhatsApp provider, SMS aggregator, courier, BPO, CRM and email platform, and the try-on SDK provider. Satisfies S.8(1)–(2).

1. **Instruction only.** The Processor shall process Personal Data received from SUGAR solely to perform the Services and solely on SUGAR's documented instructions. It shall not process such data for its own purposes, including product improvement, model training, benchmarking, or the creation of derived or aggregated datasets.
2. **Security.** The Processor shall maintain the safeguards required by Rule 6, including encryption, masking or tokenisation, access restricted to named personnel, logs retained for not less than one year, and tested backups.
3. **Breach.** The Processor shall notify SUGAR's named contact within twelve hours of becoming aware of any personal data breach, and provide everything SUGAR needs to file with the Data Protection Board within 72 hours.
4. **Sub-processing.** No sub-processor without SUGAR's prior written consent. The Processor remains liable for its sub-processors.
5. **Assistance with customer requests.** The Processor shall provide, correct or erase a customer's data on SUGAR's request within seven working days, and confirm completion in writing.
6. **Location.** The Processor shall disclose every country in which Personal Data is stored or accessed, and give thirty days' notice of any change.
7. **Return and deletion.** On termination the Processor shall return or irreversibly delete all Personal Data, including from backups within its documented cycle, and certify deletion within thirty days.
8. **Audit.** SUGAR may audit compliance once annually on reasonable notice, and at any time following a breach.

Clause 1's second sentence is the one vendors will fight hardest, because training models on customer data is how several of them make money. It matters most for the try-on SDK, where the data is facial imagery. Do not trade it away.

F. Breach runbook — the 72-hour clock

Owner: CTO with Legal. Satisfies S.8(6) and Rule 7. Rehearse once before go-live, then annually.

Clock	Who	Does what	Output
T + 0	Whoever notices	Calls the on-call number. No triage, no assessment, no waiting for confirmation. A false alarm costs an hour; a delay costs the filing window.	Incident opened, timestamped
+ 1 hour	CTO	Contains — revokes credentials, isolates the system, preserves logs before anything is rebuilt	Containment log
+ 4 hours	CTO and Data Lead	Scopes — which data classes, how many people, over what period, whether it is still live	Scoping note
+ 6 hours	Compliance lead	Decides on notification. The Board and affected individuals must be told without delay, so the default answer is yes.	Decision with reasons
+ 24 hours	Compliance lead, Legal, CX	Intimates the Board with the facts held. Notifies affected customers in plain language: what happened, what data, the likely consequences, what we have done, what they should do, and who to contact.	Filing reference; notification copy and send log
+ 72 hours	Compliance lead	Files the detailed report: the events and circumstances, remedial measures, findings on who caused it, and the intimations sent to affected people	The statutory deliverable
+ 30 days	CTO	Post-incident review; register updated with any new action	Review minutes

Fill this in now, before it is needed

On-call number Board portal login held by

Compliance lead mobile Backup

External counsel Cyber-insurance notification line

The usual failure in a breach is not technical. It is that the first person who notices spends four hours deciding whether it is serious enough to escalate. The first line of this runbook exists to take that judgement away from them.

G. Customer request workflow

Owner: Head of Customer Experience. Satisfies S.11–S.14. A right that takes three weeks of manual work to service is a complaint waiting to happen.

Step	Who	Action	Target
Intake	Automated	One route: privacy@sugarcosmetics.com and the in-app form. Auto-acknowledged with a reference.	Immediate
Verify	CX agent	OTP to the registered mobile. Do not ask for identity documents — that collects more data to answer a question about data.	2 working days
Classify	CX agent	Access, correction, erasure, nomination, withdrawal or grievance. Each routes differently.	Same day
Fan out	CX agent	Issue to every system owner on the processor register. Access must also name every fiduciary and processor the data was shared with. Erasure has to cascade to all of them, not just the app.	5 working days
Execute	System owners	Action taken and confirmed in writing	7 working days
Close	CX agent	Tell the customer what was done. For erasure, say what was kept and why — a partial erasure explained is fine, a silent one is not.	30 days; the outer limit for grievance resolution is 90
Log	Automated	Request, type, dates and outcome retained as the evidence trail	On close

Build the erasure path first, not the access path. Access is a read across systems; erasure is a write across systems, and it is the one that breaks — a record deleted from the app but still sitting in the email platform will keep receiving campaigns. Test it end to end on a real account before go-live.

H. Provisions relied on

Provision	What it requires
S.3(a)	The Act applies to digital personal data processed within India, and to processing outside India connected with offering goods or services to people in India
S.3(c)(ii)	It does not apply to personal data the individual has made publicly available
S.5 and Rule 3	An itemised, standalone notice at the point of collection: the data field by field, the specified purpose, how to exercise rights, how to withdraw, how to complain to the Board, and the contact answering data questions — in plain language, in English or an Eighth Schedule language
S.6(1)	Consent must be free, specific, informed, unconditional and unambiguous, given by a clear affirmative action, and limited to the data necessary for the specified purpose
S.6(4)–(6)	Withdrawal must be as easy as giving, and processing must stop within a reasonable time
S.7	A closed list of legitimate uses permits processing without consent. Marketing, advertising, profiling, personalisation and analytics are not on it
S.8(1)–(2)	The Data Fiduciary remains responsible for processing done by a processor on its behalf, and requires a valid contract with it
S.8(3)–(4)	Purpose limitation, data minimisation, and accuracy where the data drives a decision affecting the person
S.8(5) and Rule 6	Reasonable security safeguards — encryption, masking or tokenisation, access control, logs retained a year, backups, and contractual obligations on processors
S.8(6) and Rule 7	Intimate affected individuals and the Board without delay; detailed report to the Board within 72 hours
S.8(7) and Rule 8	Erase once the purpose is served or consent is withdrawn, and cause processors to erase. The Third Schedule adds a fixed clock and a 48-hour pre-erasure notice for specified classes of entity
S.8(9) and S.13	Publish the contact answering data questions, and provide a grievance mechanism the individual must exhaust before approaching the Board. Resolution is capped at 90 days
S.9 and Rule 10	A child is anyone under eighteen. Verifiable parental consent before processing; tracking, behavioural monitoring and targeted advertising directed at children are prohibited outright; reasonable and appropriate measures to establish age
S.10	Significant Data Fiduciary duties on notification — a Data Protection Officer resident in India and answerable to the board, an independent annual audit, a periodic impact assessment, and algorithmic due diligence
S.11 to S.14	Rights of access including the identities of everyone the data was shared with, correction and erasure, grievance redressal, and nomination
S.15	Duties on the individual, with a penalty up to ₹10,000 — impersonation, suppression of material information and frivolous complaints
S.16	Cross-border transfer is permitted except to countries the Government restricts by notification. Sectoral rules continue to apply
S.33 and the Schedule	Penalties per breach category: ₹250 crore for security safeguards, ₹200 crore for breach notification, ₹200 crore for the children's obligations, ₹150 crore for Significant Data Fiduciary duties, ₹50 crore otherwise. They stack
Rule 4	Consent Managers register with the Board from 13 November 2026, with a minimum net worth requirement, and must not read the contents of the data they broker
Commencement	Rules notified 13 November 2025 with the Board constituted and definitions operative; Rule 4 from 13 November 2026; the operating obligations from 13 May 2027

I. Sources

The Digital Personal Data Protection Act, 2023 and the Digital Personal Data Protection Rules, 2025 as notified on 13 November 2025.

Course material: the session deck *DPDP_Act_Marketing_Retail_Analytics* — relied on for the commencement clock and the consultation on compressing it (slide 4), the five roles and where liability sits (slide 5), the eight fiduciary obligations (slide 7), the six qualifiers of consent and the language requirement (slide 8), the itemised notice and the worked till example (slide 9), the closed list of legitimate uses (slide 10), the rights and the 90-day cap (slide 11), the children's clause (slide 13), the Significant Data Fiduciary duties (slide 14), the security list and the breach clock (slide 15), retention and the specified classes (slide 16), cross-border transfer and the Consent Manager (slide 17), the stacking of penalties (slide 18), the Board and the exhaustion requirement (slide 19), the comparison with GDPR (slide 20), the retail practices this breaks (slide 21), the six analytics consequences (slide 22), what to build instead (slide 23), and the ten-step compliance path (slide 24).

Trade press for scale figures on outlet count, city coverage and the offline share of revenue. These are marked in the limitations and nothing is computed from them.